

Ethics, Privacy, and Regulation in Informatics

Laboratórios de Sistemas e Serviços

Mário Antunes

Universidade de Aveiro

2026

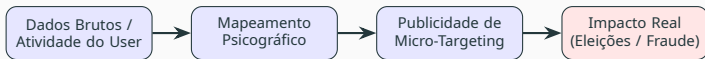
Ética em Informática

O Impacto da Recolha e Partilha de Dados i

- **Data is Power:** Na era digital, “Dinheiro é uma coisa, mas dados são poder”. Os dados moldam o discurso público, influenciam mercados e governam comportamentos individuais.
- **Consequências no Mundo Real:**
 - **Manipulação Política:** Empresas de análise de dados (ex: Cambridge Analytica) usaram dados pessoais para construir perfis psicográficos, fazendo *micro-targeting* de eleitores e influenciando potencialmente resultados democráticos como o Brexit e as eleições presidenciais dos EUA em 2016.
 - **Fraude Financeira:** Dados vazados ou mal geridos podem levar ao roubo de identidade e perdas financeiras graves, onde as instituições frequentemente descartam responsabilidade culpando os utilizadores por “phishing” ou negligência, apesar de vulnerabilidades sistémicas.

O Impacto da Recolha e Partilha de Dados ii

- **O Imperativo Ético:** Como *developers*, devemos reconhecer que por trás de cada *data point* existe um ser humano com direitos fundamentais. Decisões de software impactam vidas, segurança e dignidade.

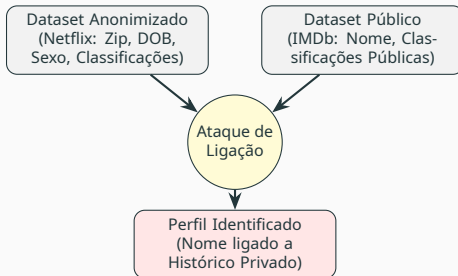


Identificação Indireta i

- **O Mito dos Dados “Anónimos”:** Remover identificadores diretos (como nomes, IDs ou emails) é frequentemente insuficiente para proteger a identidade individual.
- **Definição:** Uma pessoa é “identificável” se puder ser distinguida não apenas diretamente, mas **indiretamente** combinando fatores como localização, idade, género, código postal ou características físicas.
- **Quase-Identificadores:** Atributos que não identificam unicamente alguém por si só, mas que o fazem quando cruzados com outras bases de dados.
- **Riscos de Reidentificação:**
 - Estudos mostram que **87%** da população dos EUA poderia ser identificada de forma única usando apenas três *data points*: **Código Postal, Data de Nascimento e Sexo.**

- **Exemplo:** O *dataset* do “Netflix Prize” foi anonimizado ao remover nomes. No entanto, investigadores reidentificaram utilizadores específicos e expuseram o seu histórico privado de classificações de filmes cruzando dados (*cross-referencing*) com perfis públicos do IMDb.
- **Lição:** Assumam sempre que os dados podem ser reassociados. Com o aumento do poder computacional, o termo “anonimizado” deve ser tratado com extremo ceticismo técnico.

Identificação Indireta iii



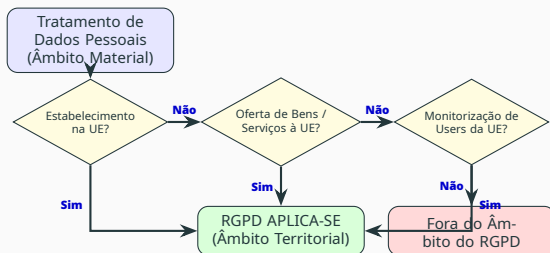
RGPD (GDPR) e Garantia de Privacidade

O que é o RGPD? i

- **Regulamento (UE) 2016/679:** O Regulamento Geral sobre a Proteção de Dados (RGPD/GDPR), em vigor desde 25 de maio de 2018.
- **Filosofia Central:** A privacidade é um **direito humano fundamental**, não um luxo. O utilizador é proprietário dos seus dados; as organizações são meras guardiãs temporárias.
- **Âmbito de Aplicação:**
 - **Âmbito Material:** Aplica-se ao tratamento de dados pessoais por meios total ou parcialmente automatizados, ou manual estruturado.

O que é o RGPD? ii

- **Âmbito Territorial (Alcance Extraterritorial):**
Aplica-se a *qualquer* entidade que processe dados de residentes da UE, independentemente de onde o processamento ocorra (ex: um serviço de cloud baseado nos EUA que vise utilizadores na UE deve cumprir integralmente o RGPD).



O Nível de Privacidade que Devemos Fornecer i

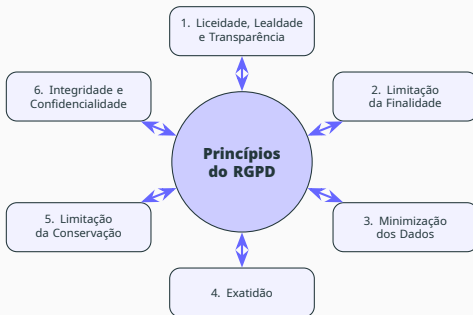
Os *developers* devem garantir que os sistemas aderem estritamente a estes **6 + 1 princípios chave**:

1. **Liceidade, Lealdade e Transparência:** Sem processamento oculto. Utilizadores devem saber exatamente como e porquê os seus dados são tratados através de políticas claras.
2. **Limitação da Finalidade:** Dados recolhidos para o “Projeto A” não podem ser reutilizados para o “Projeto B” ou perfis de anúncios sem novo consentimento explícito.
3. **Minimização dos Dados:** Recolher apenas o estritamente necessário. Não pedir o número de telefone quando apenas o email é necessário.

O Nível de Privacidade que Devemos Fornecer ii

4. **Exatidão:** Os dados devem estar corretos e atualizados, oferecendo interfaces de fácil acesso para os utilizadores retificarem incorreções.
5. **Limitação da Conservação:** Apagar dados quando deixarem de ser necessários. Criar rotinas automáticas de eliminação para contas expiradas.
6. **Integridade e Confidencialidade:** Garantir a segurança física e lógica contra acessos não autorizados, perda ou vazamento através de encriptação, controlo de acessos e hashing robusto (ex: bcrypt).
7. **Responsabilidade (Accountability):** O responsável pelo tratamento (*controller*) deve ser capaz de *demonstrar* a conformidade através de documentação técnica detalhada e logs de auditoria.

O Nível de Privacidade que Devemos Fornecer iii



7. Accountability (Responsabilidade)

- **By Design:** Medidas de privacidade devem ser embutidas na própria arquitetura do software desde o início, não adicionadas como um remendo (*patch*) posterior.
 - *Os 7 Princípios Fundacionais:* Proativo, preventivo, predefinição, embutido no design, funcionalidade total (soma positiva), segurança de ponta a ponta e respeito pela privacidade.
- **By Default:** As definições de privacidade mais estritas aplicam-se automaticamente sem intervenção do utilizador (ex: o perfil de rede social deve ser privado por defeito, e a partilha de localização deve ser sempre opt-in).

Privacy by Design & Default ii

- **Responsabilidade (Accountability):** O responsável pelo tratamento (*controller*) deve manter logs detalhados e documentação técnica que permitam demonstrar a conformidade perante as autoridades a qualquer momento.

Privacy by Design

Integrado no Ciclo de Vida
(Requisitos → Design → Código)

Funcionalidade Total
(Soma-Positiva:
Sem Trade-offs)

Segurança Ponta-a-Ponta
(Proteção Contínua)

Privacy by Default

Definições Mais Estritas
Aplicadas Automaticamente

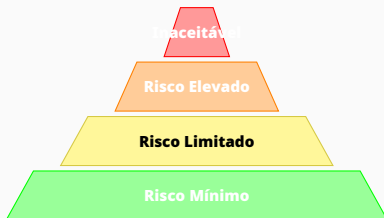
Minimização de Dados
por Defeito

Opção do Utilizador
para Partilhar Mais

AI Act Europeu

- **Abordagem Baseada no Risco:** O AI Act categoriza os sistemas de Inteligência Artificial com base no risco potencial que representam para a segurança, meios de subsistência e direitos fundamentais.
- **As 4 Categorias de Risco:**
 - **Risco Inaceitável:** Banido de imediato (ex: *social scoring*, manipulação comportamental cognitiva e identificação biométrica remota em tempo real em espaços públicos pelas forças de segurança, com poucas exceções).
 - **Risco Elevado:** Permitido mas estritamente regulado (ex: IA na educação, triagem de currículos para emprego, infraestruturas críticas, diagnóstico médico).
 - **Risco Limitado:** Obrigações de transparência (ex: *chatbots* devem revelar que são IA).
 - **Risco Mínimo:** Não regulado (ex: filtros de *spam*).

Visão Geral do AI Act ii



Proibido: Pontuação social, biometria em tempo real (com exceções)

Regulado: IA na saúde, triagem de CVs, infraestruturas críticas

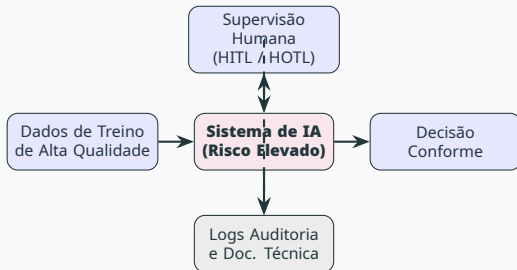
Transparência: Chatbots, deep-fakes, conteúdos gerados por IA

Não Regulado: Filtros de spam, videojogos, analítica básica

- **Relação com a Privacidade:** Sistemas de IA de alto risco devem correr sobre dados de treino de alta qualidade, representativos e imparciais para evitar discriminações. Devem aderir aos princípios do RGPD, como a governança e segurança de dados.
- **Requisitos de Auditabilidade:**
 - **Logging:** Os sistemas devem registar eventos de funcionamento automaticamente (*logs*) para rastrear a sua operação e detetar vieses ou falhas em tempo real.
 - **Documentação Técnica:** Os *developers* devem construir e manter documentação detalhada sobre a arquitetura do algoritmo, o processo de treino e critérios de validação.
 - **Supervisão Humana:** Desenhar sistemas para permitir supervisão por pessoas naturais, que podem intervir, corrigir ou anular decisões:

Privacidade e Auditabilidade em IA ii

1. *Human-in-the-loop (HITL)*: Intervenção e aprovação humana ativa em cada decisão.
2. *Human-on-the-loop (HOTL)*: Monitorização ativa com capacidade de override técnico.
3. *Human-in-command (HIC)*: Supervisão geral sobre a aplicação e desativação do sistema.

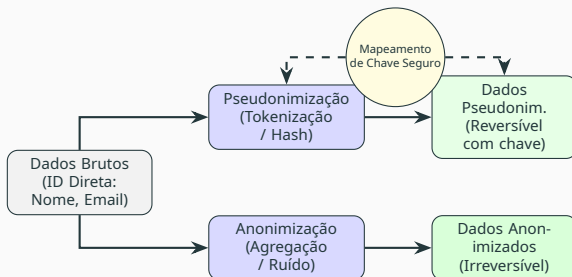


Como nos Protegermos e aos Nossos Utilizadores

Garantir Proteção: Medidas Técnicas i

- **Pseudonimização:** Tratamento de dados de forma a que estes já não possam ser atribuídos a um titular específico sem informação adicional (chaves), que deve ser mantida separada e protegida.
- **Anonimização:** Remoção irreversível de todos os identificadores diretos e indiretos.
 - *Nota Legal:* Dados verdadeiramente anonimizados caem completamente fora do âmbito do RGPD. No entanto, provar matematicamente a irreversibilidade da anonimização (ex: contra futuros ataques de ligação) é extremamente difícil.
- **Encriptação:** O padrão de segurança obrigatório para dados sensíveis:
 - *Em Trânsito:* Dados que viajam na rede (TLS 1.3).
 - *Em Repouso:* Dados armazenados em discos ou bases de dados (AES-256).

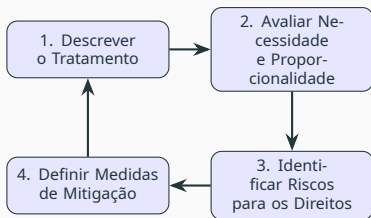
Garantir Proteção: Medidas Técnicas ii



- **Avaliação de Impacto sobre a Proteção de Dados (DPIA/AIPD):**

- Obrigatória antes de iniciar qualquer projeto de tratamento com riscos elevados (ex: vigilância de espaços públicos, processamento em larga escala de dados de saúde).
- **Os 4 Passos Essenciais:**
 1. **Descrever:** Documentar as operações de processamento e finalidades.
 2. **Avaliar:** Analisar a necessidade e proporcionalidade dos dados recolhidos.
 3. **Identificar:** Mapear os potenciais riscos para os direitos e liberdades.
 4. **Definir:** Estabelecer medidas técnicas e organizativas para mitigar os riscos.

- **Gestão de Consentimento:** O consentimento sob o RGPD deve ser **livre, específico, informado e explícito**. Caixas pré-assinaladas ou cláusulas ocultas são legalmente inválidas. Deve ser tão fácil retirar o consentimento como o dar.



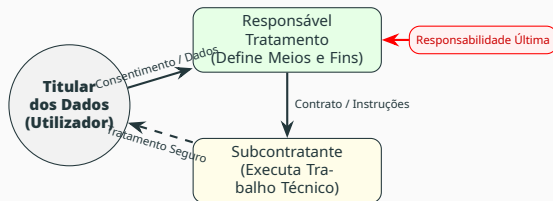
- **Responsabilidade Clara:**

- **Responsável pelo Tratamento (Controller):** A entidade que determina as finalidades e meios do tratamento dos dados. Detém a responsabilidade jurídica última.
- **Subcontratante (Processor):** A entidade que trata os dados pessoais em nome e sob as instruções do responsável pelo tratamento.
- *Dever do Programador:* Mesmo sob instruções, o programador deve alertar se as ordens violarem as leis de proteção de dados e garantir a segurança lógica do software.

- **Vigilância Contínua:**

- Monitorizar riscos de reidentificação à medida que os volumes de dados crescem (*big data*).

- Conhecer o enquadramento de **Transferências Internacionais de Dados** (ex: cláusulas contratuais-tipo - SCCs, e regimes de adequação ao guardar dados em servidores nos EUA).



1. Textos Legais Oficiais:

- [RGPD \(UE 2016/679\) Texto Completo](#)
- [Texto do AI Act Europeu](#)

2. Manuais:

- [*Handbook on European Data Protection Law*](#) (FRA/Conselho da Europa).

3. Orientação Institucional:

- Contactos do *Data Protection Officer* (DPO) na tua instituição [aqui](#)
- CNPD (Comissão Nacional de Proteção de Dados) [diretrizes](#).